

逻辑漏洞

1 返回凭证

2 暴力破解用户名和密码

3 验证码爆破

4 验证码绕过

5 短信轰炸

6 session覆盖

7 支付逻辑漏洞

大米 cms复现

8 越权漏洞

pikachu水平越权复现

pikachu垂直越权复现

海洋cmsV9水平越权复现

metinfoV4.0垂直越权复现

9 任意用户密码重置漏洞

dedecmsV5.7复现

10 条件竞争

upload-labs第18关复现

业务逻辑漏洞，是由于程序逻辑不严谨或逻辑太过复杂，导致一些逻辑分支不能正常处理或处理错误，这样的漏洞统称为业务逻辑漏洞。

简单理解：就是编程人员的思维逻辑不够严谨导致攻击者有机可乘的漏洞。

常见漏洞出现位置：

返回凭证

暴力破解用户密码

逻辑漏洞

登录页面

登录

- 验证码登录爆破
- 验证码登录绕过
- 短信轰炸
- Session覆盖

注册

- 任意用户注册
- 短信轰炸
- 返回凭证
- 注册覆盖

密码找回

- 任意用户密码重置
- 短信轰炸
- 返回凭证

会员系统

用户越权访问

订单越权查看修改

收货地址越权查看修改

资料越权查看修改

换绑手机修改

换绑短信轰炸

水平垂直越权

支付系统

运费修改

商品价格修改

商品数量修改

支付金额修改

优惠券金额修改

优惠券数量修改

积分修改

1 返回凭证

将验证码、密码等直接返回到客户端，直接就可以输入验证码，可以完成任意用户登录，注册，密码找回。

2 暴力破解用户名和密码

在登陆部分没有验证码机制，没有根据用户名限制失败次数，没有根据ip限制失败次数等情况下，可以进行暴力破解。

在存在返回提示用户名错误或者密码错误的情况下，可以分别爆用户名和密码。

3 验证码爆破

有些系统，手机获取验证码的时候，没有对验证码的验证次数进行限制，或者是没有对验证码的有限时间进行限制，就会造成验证码爆破。

4 验证码绕过

由于逻辑设计缺陷，有些直接删除COOKIE或验证码参数可绕过。

在需要手机号的短信验证处，抓包修改手机号，可能做到非本账号手机号获取能够编辑本账号的验证码。

验证码直接由客户端生成和校验，可逆向JS绕过。

响应包中存在标记位判断是否验证通过，可修改响应包绕过。

5 短信轰炸

有对单个用户获取验证码的次数进行限制，通过burp抓包，数据包重放就可以造成短信轰炸。

6 session覆盖

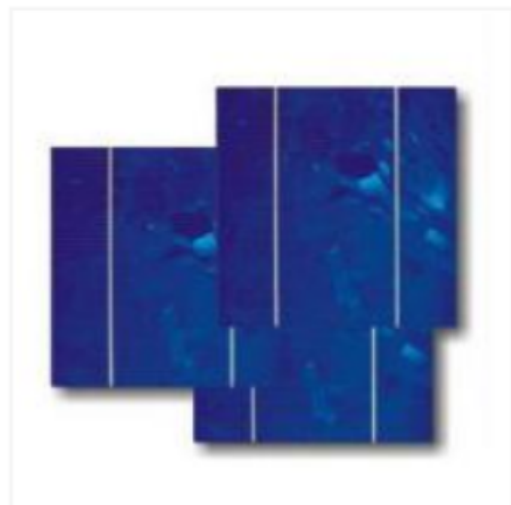
- (1)需要准备自己的账号接收短信验证码;
- (2)校验成功后进入密码重置页面;
- (3)在浏览器新标签重新打开找回密码页面, 输入目标手机号;
- (4)此时当前 session 账户已经被覆盖, 重新回到第二步中打开的重置密码页面即可重置目标手机号。

7 支付逻辑漏洞

- (1)数据包中暴露了参数, 可以直接修改价格数量, 产生零元购
- (2)响应包中有字段代表支付成功或失败, 可以修改该字段
- (3)购买A商品, 是10元, B商品是1000元, 我们先购买A商品, 将A商品的数据包, 给B商品, 那么我们就通过10元购买10000元的商品
- (4)修改优惠券的id, 可以使用其他优惠券
- (5)如果充值0.019, 由于支付宝只判断到分, 所以导致只能支付0.01, 而由于我们支付成功, 前端会将9四舍五入, 直接变成0.02, 所以等于直接半价充值
- (6)很多会员什么的, 为了留住用户, 都会有首月半价, 或者免费等等活动, 我们可以抓取这个数据包, 进行多次支付, 就可以一直优惠购买(百度云曾经有过这个漏洞)
- (7)在支付当中会出现当前用户的ID, 比如ID=1, 我们将ID改为2, 如果没有加以验证, 我们可以用用户2的钱支付了用户1买商品的钱

大米 cms复现

登录后, 随便找个商品进行购买



大米CMS手机开发专版

更新：2014-02-24 09:56:18

点击: 34

型号: M002456J

颜色： 灰色

价格：5400 元

数量: 1

[立即购买](#)

 加入购物车

介绍

大米CMS手机,开发专版大米CMS手机,开发专版大米CMS手机,开发专版大米CMS手机,开发专版

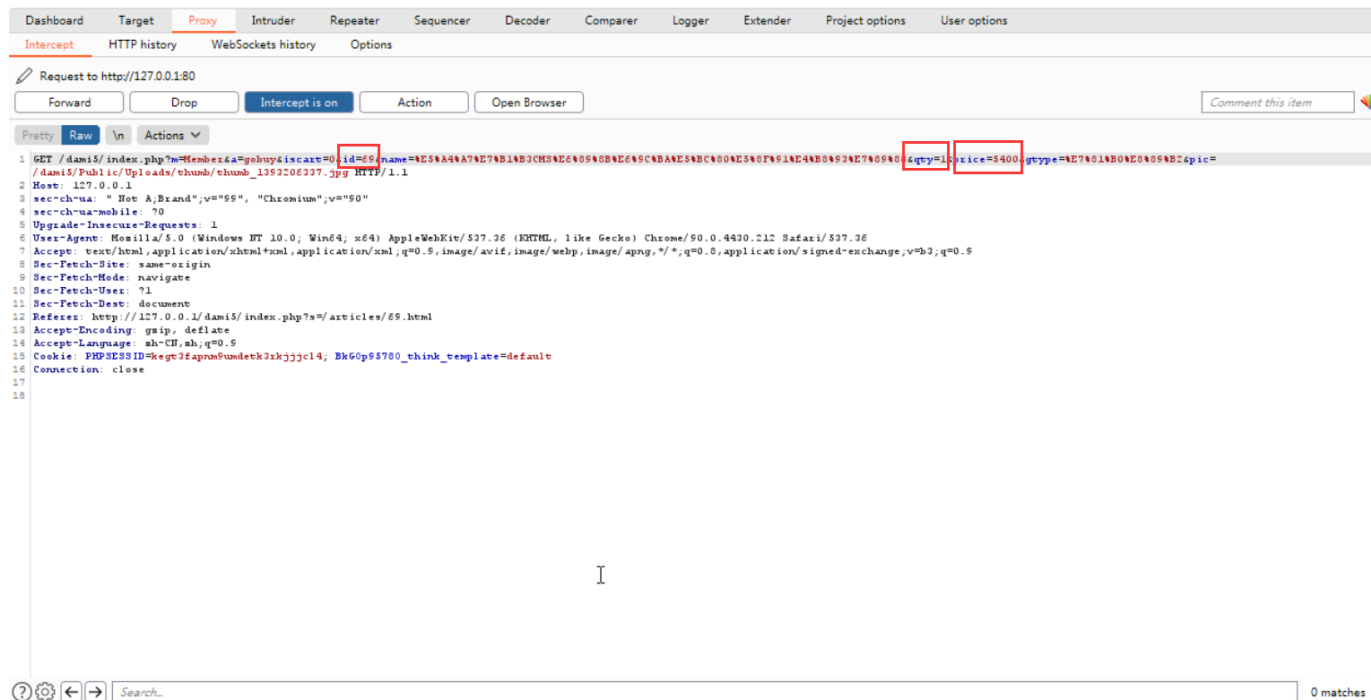
评论



 以下是网友对 大米CMS手机开发专版 的评论:

暂时还没有评论

抓包，发现里面有id，数量，价格等参数，这里直接修改数量为-1，价格为100



发现价格和数量都被改了，提交订单并抓包

你的位置：首页 > 用户下单

订单列表

编号	名称	型号	数量	单价	小计
69	 大米CMS手机开发专版	灰色	-1	100	-100

送货地址(可修改)

姓名	手机	区域	详细地址	付款方式
xxx	12345678910	四川 成都市 武侯区	xxxxxxxxxxxxxxxxxxxxxxxxxxxx	站内扣款

合计：-100元 提交订单

[关于我们](#) | [新闻动态](#) | [公司荣誉](#) | [联系我们](#) | [售后服务](#) | [人力资源](#)

这里的参数还可以继续修改，这里修改数量为-10，价格为999。发现下单成功，只有数量是真正的被修改了。

你的位置：首页 > 会员订单

会员订单列表

订单号	产品名称/型号	价格	数量	状态
GB1691134162-9	大米CMS手机开发专版/灰色	5400.00	-10	已付款，等待发货 评价

8 越权漏洞

由于没有对用户权限进行严格的判断，导致普通用户可以去完成超出权限范围内的操作。

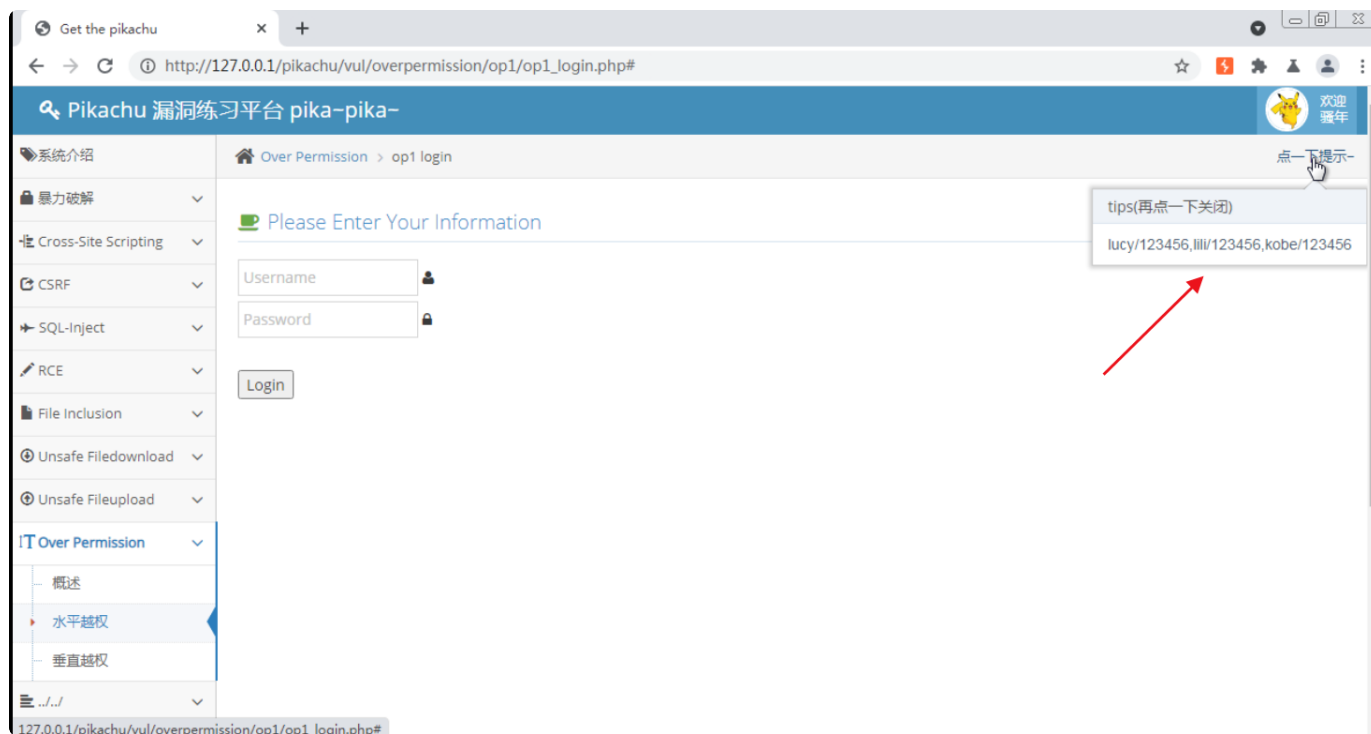
越权漏洞主要分为水平越权和垂直越权两大类。

水平越权：同级别（权限）的用户或者同一角色的不同用户之间，可以越权访问。

垂直越权：一般是权限低的用户可以完成权限较高的用户的操作。

pikachu水平越权复现

点击提示，一共有三个用户，这里从lucy越权到lili



登录到lucy，可以看到url的name参数为lucy



修改name为lili，可以看到成功获取到lili的信息



pikachu垂直越权复现

登录到admin，并添加一个新用户，抓包


```
Request
Pretty Raw ↵ Actions ▼
1 POST /pikachu/vul/overpermission/op2/op2_admin_edit.php HTTP/1.1
2 Host: 127.0.0.1
3 Content-Length: 86
4 Cache-Control: max-age=0
5 sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="90"
6 sec-ch-ua-mobile: ?0
7 Upgrade-Insecure-Requests: 1
8 Origin: http://127.0.0.1
9 Content-Type: application/x-www-form-urlencoded
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
    Chrome/90.0.4430.212 Safari/537.36
11 Accept:
    text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,a
    pplication/signed-exchange;v=b3;q=0.9
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer: http://127.0.0.1/pikachu/vul/overpermission/op2/op2_admin_edit.php
17 Accept-Encoding: gzip, deflate
18 Accept-Language: zh-CN,zh;q=0.9
19 Cookie: safedog-flow-item=; PHPSESSID=93qnljtoakv94hikq63k4dni31; _csrf_name_6e00c81a=
    008959da9128d9779b69021022e43e10; _csrf_name_6e00c81a__ckMd5=2e403dcb1cc5c5df; last_vtime=
    1691108494; last_vtime__ckMd5=5ecac88f921a61a9; last_vid=test; last_vid__ckMd5=17f3b0414c57d039
20 Connection: close
21
22 username=11111&password=11111&sex=&phonenum=&email=&address=&submit=%E5%88%9B%E5%B5%BB%E5%A
```

切换到普通用户pikachu，用pikachu的cookie替换admin用户的cookie，成功创建新用户22222

```
Request
Pretty Raw ↵ Actions ▼
1 POST /pikachu/vul/overpermission/op2/op2_admin_edit.php HTTP/1.1
2 Host: 127.0.0.1
3 Content-Length: 86
4 Cache-Control: max-age=0
5 sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="90"
6 sec-ch-ua-mobile: ?0
7 Upgrade-Insecure-Requests: 1
8 Origin: http://127.0.0.1
9 Content-Type: application/x-www-form-urlencoded
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
    Chrome/90.0.4430.212 Safari/537.36
11 Accept:
    text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,a
    pplication/signed-exchange;v=b3;q=0.9
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer: http://127.0.0.1/pikachu/vul/overpermission/op2/op2_admin_edit.php
17 Accept-Encoding: gzip, deflate
18 Accept-Language: zh-CN,zh;q=0.9
19 Cookie: safedog-flow-item=; PHPSESSID=93qnljtoakv94hikq63k4dni31; _csrf_name_6e00c81a=
    008959da9128d9779b69021022e43e10; _csrf_name_6e00c81a__ckMd5=2e403dcb1cc5c5df; last_vtime=
    1691108494; last_vtime__ckMd5=5ecac88f921a61a9; last_vid=test; last_vid__ckMd5=17f3b0414c57d039
20 Connection: close
21
22 username=22222&password=22222&sex=&phonenum=&email=&address=&submit=%E5%88%9B%E5%B5%BB%E5%A

? ⚙️ ⬅️ ➡️ Search... 0 matches
Done
```

Over Permission > op2 user 点一下提示

欢迎来到后台管理中心,您只有查看权限! | [退出登录](#)

用名	性别	手机	邮箱	地址
vince	boy	18626545453	vince@pikachu.com	chain
11111				
kobe	boy	15988767673	kobe@pikachu.com	nba lakes
grady	boy	13676765545	grady@pikachu.com	nba hs
kevin	boy	13677676754	kevin@pikachu.com	Oklahoma City Thunder
lucy	girl	12345678922	lucy@pikachu.com	usa
lili	girl	18656565545	lili@pikachu.com	usa
22222				

海洋cmsV9水平越权复现

注册两个普通用户

aaaa / 123456

bbbb / 123456

会员中心

http://127.0.0.1/seacms/member.php

基本资料 我的收藏 购买记录 返回首页

我要签到 +金币

会员编号：1

您的账户：aaaa

您的邮箱：aaaa@qq.com

联系方式：

登陆次数：2

会员时限：无限期

用户级别：普通会员

升级会员：

铜牌会员(100金币/月)

银牌会员(500金币/月)

金牌会员(1000金币/月)

钻石会员(3000金币/月)

当前积分：10 金币

推广链接：127.0.0.1/i.php?uid=1

充值积分：

输入充值卡卡号

充值金币

修改资料

.....

输入新密码

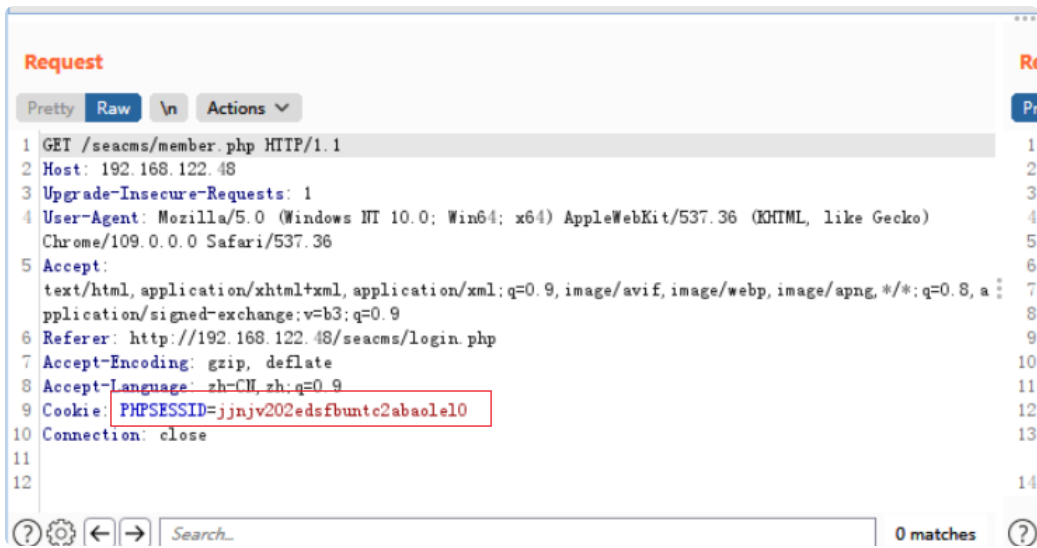
再次确认

aaaa@qq.com

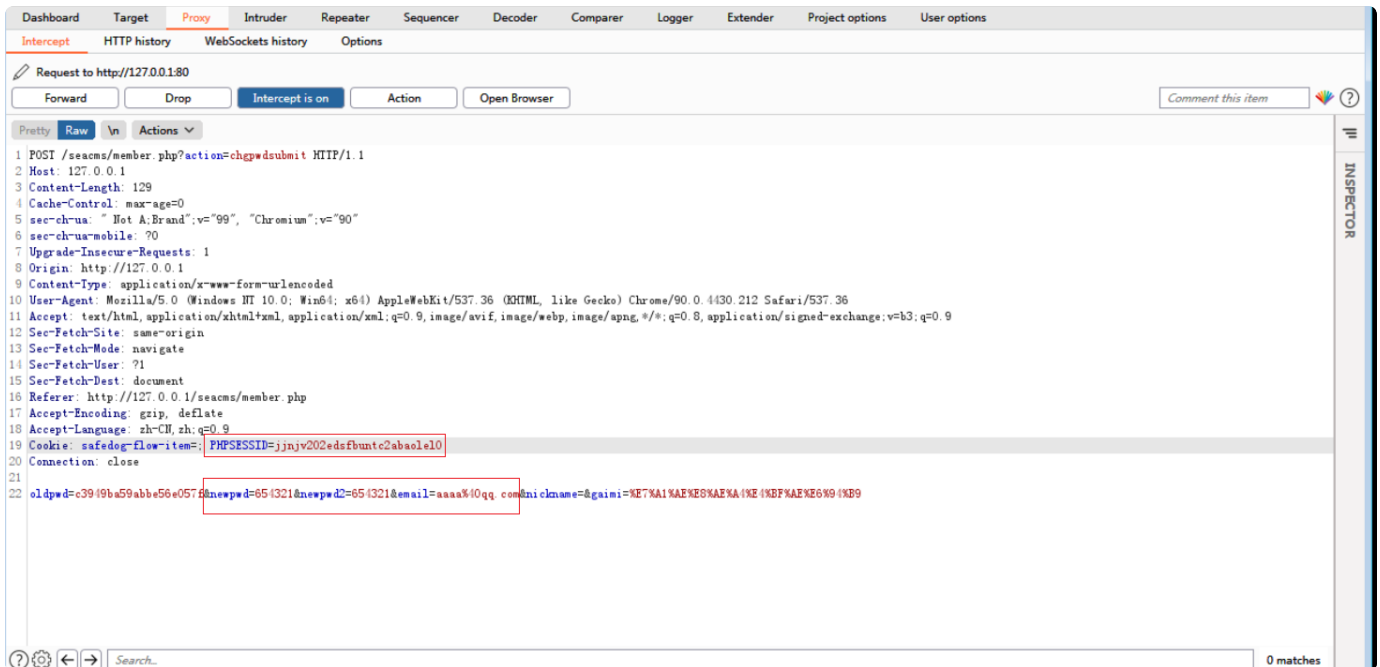
联系方式

确认修改

在一个浏览器上登录aaaa，另一个浏览器上登录bbbb，抓包得到bbbb的sessionid



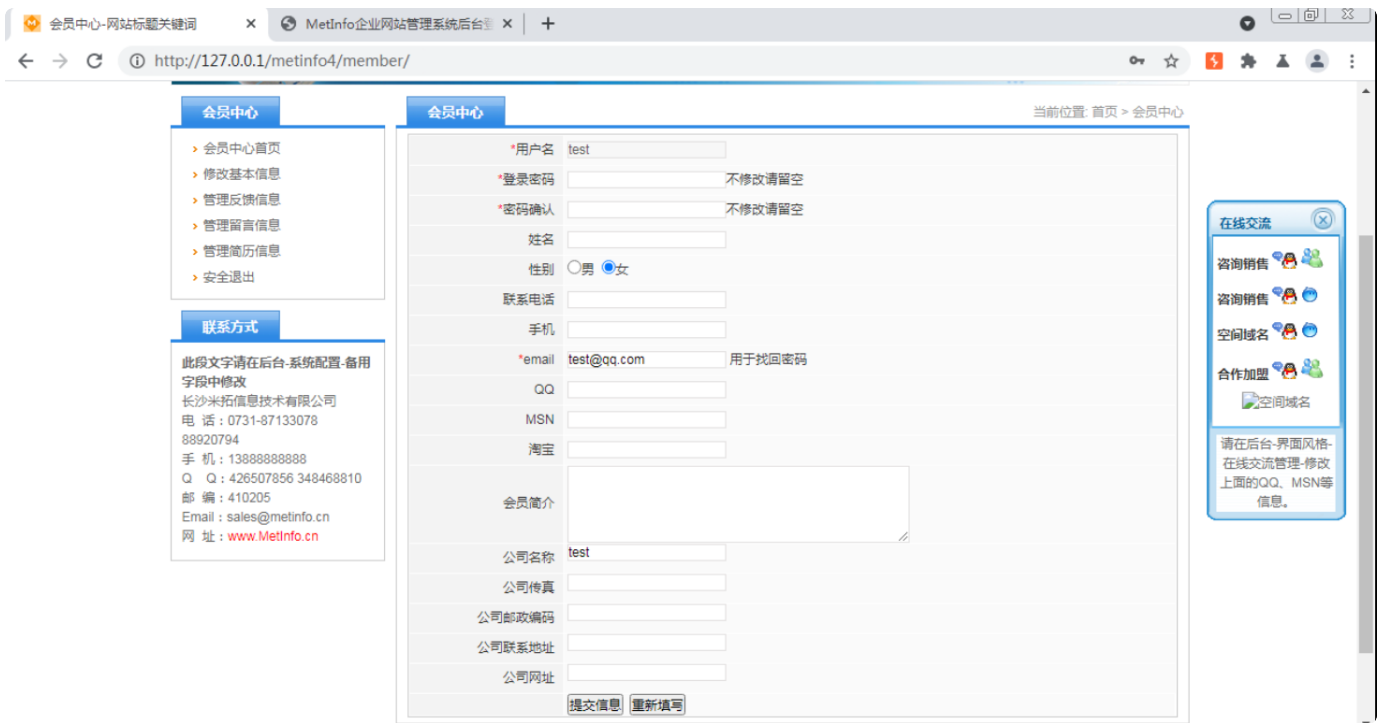
对aaaa的改密码操作进行抓包，并把sessionid替换成bbbb的sessionid



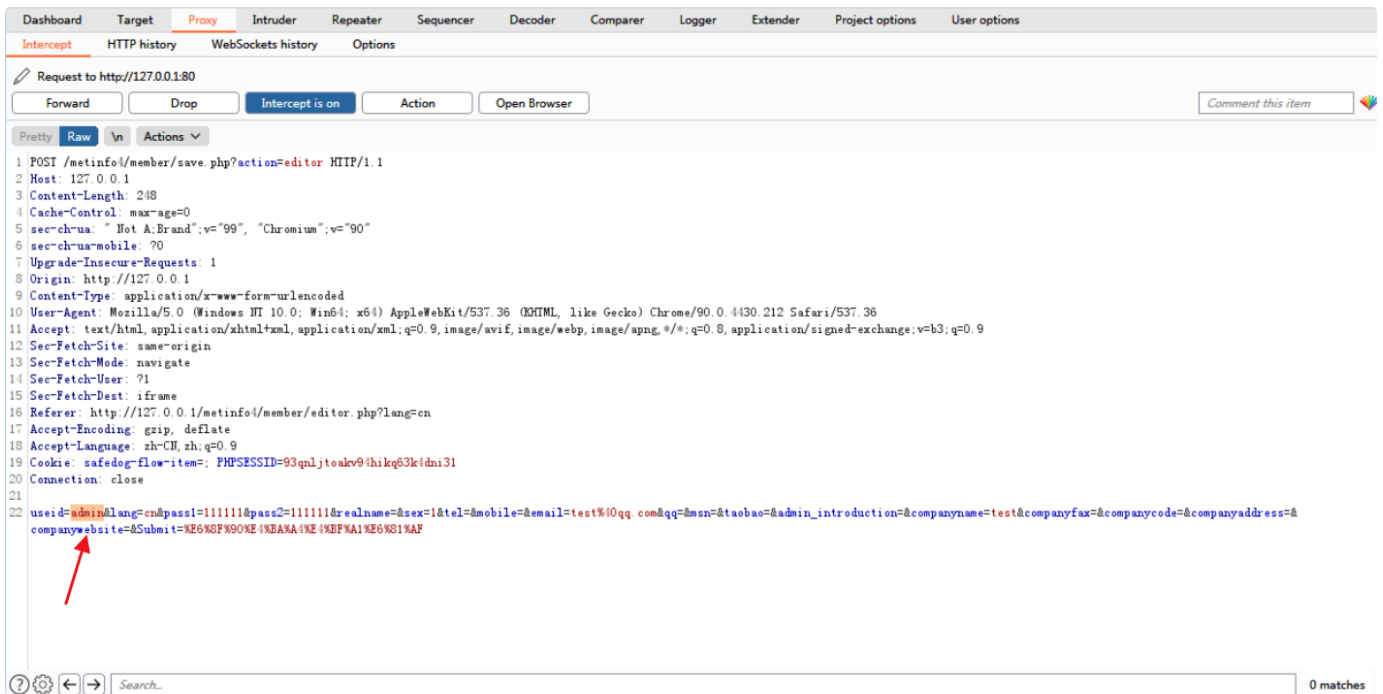
显示修改成功，bbbb的密码被改成了654321

metinfoV4.0垂直越权复现

注册一个普通用户test，进入修改基本信息的页面



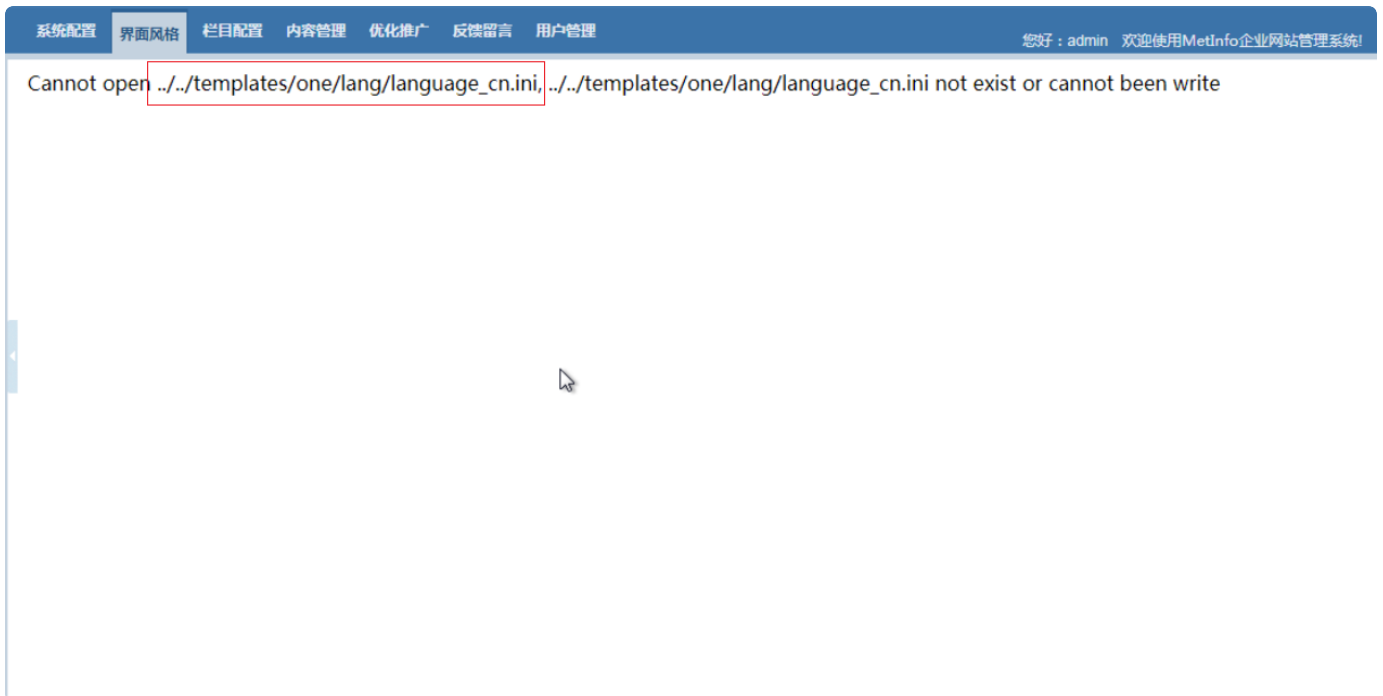
随便修改一个密码，并抓包修改userid为管理员id (admin)



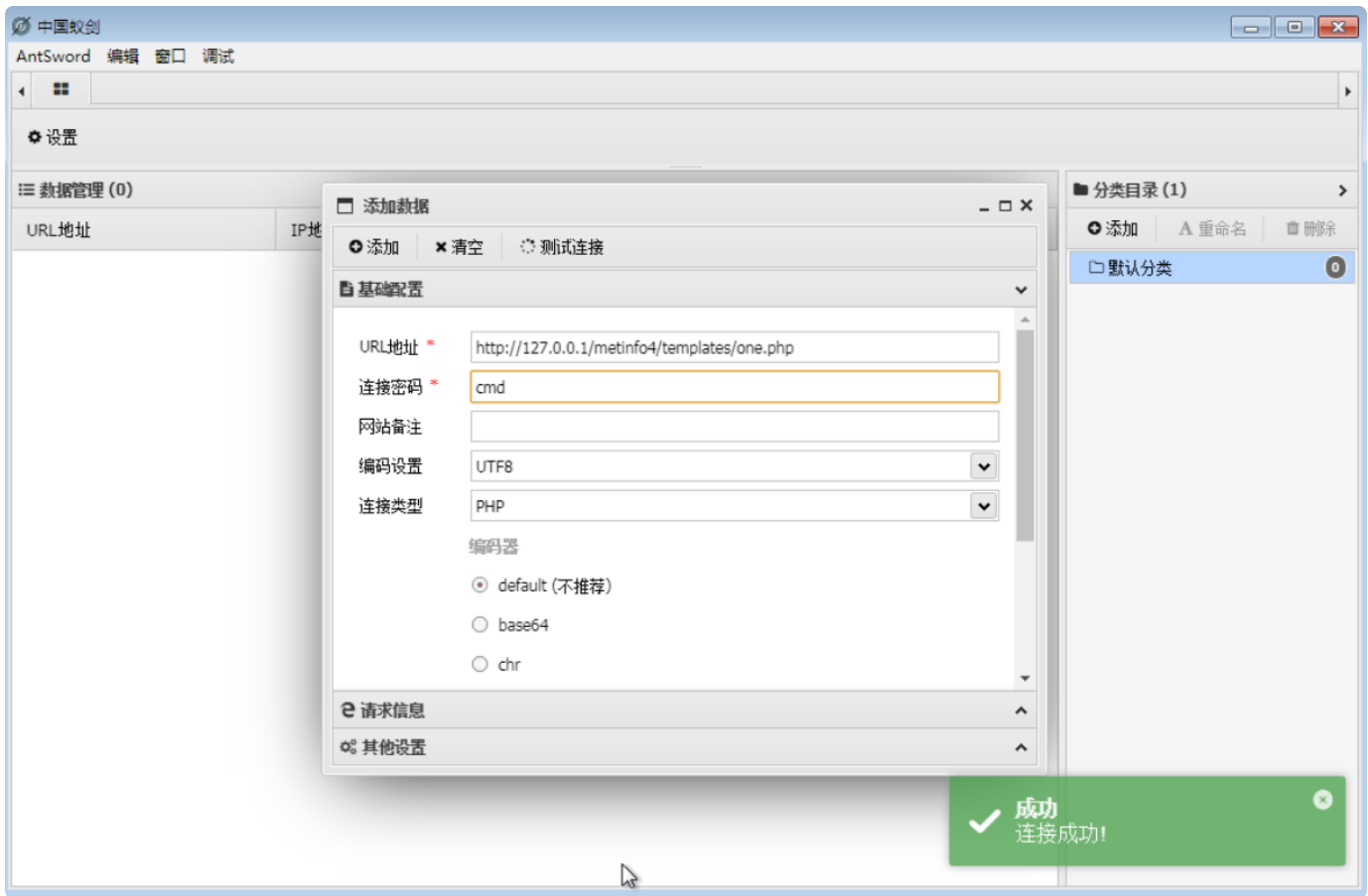
此时管理员的密码被修改了，并能成功登录后台



在界面风格->模板管理->添加新模板有一处文件上传漏洞，将一句话木马压缩成zip文件成功上传，再查看一下编辑模板参数，报错回显出木马路径



最后通过蚁剑成功拿到shell



9 任意用户密码重置漏洞

- (1)验证码可爆破
- (2)验证码回传
- (3)验证码未绑定用户，任意手机可接收验证码
- (4)本地前端验证绕过
- (6)跳过验证步骤，直接跳转到改密码页面
- (7)token可预测
- (8)将发送验证码的包截获，修改字段添加多个账户，同时向多个账户发送凭证均可收到验证码
- (9)开发为了方便测试，加了888888、000000这样的万能验证码

dedecmsV5.7复现

进入后台，系统->系统设置->系统基本参数->会员设置，将是否开启会员功能一栏调为"是"



注册几个个人账号，不设置安全问题



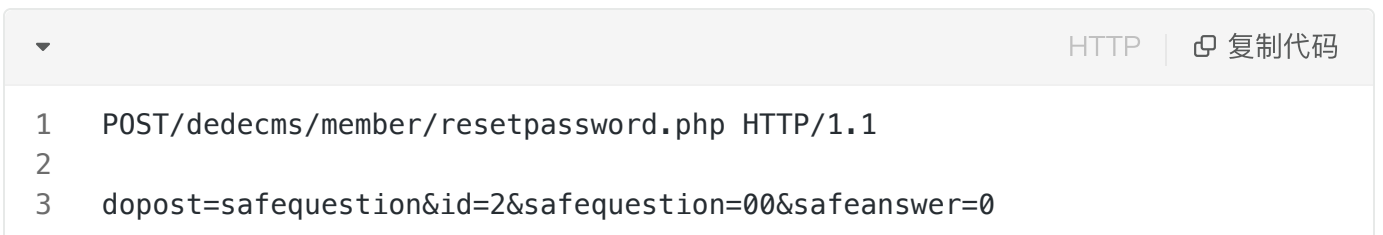
回到后台，将所有用户等待验证邮件修改为：“审核通过，提示填写完整信息”



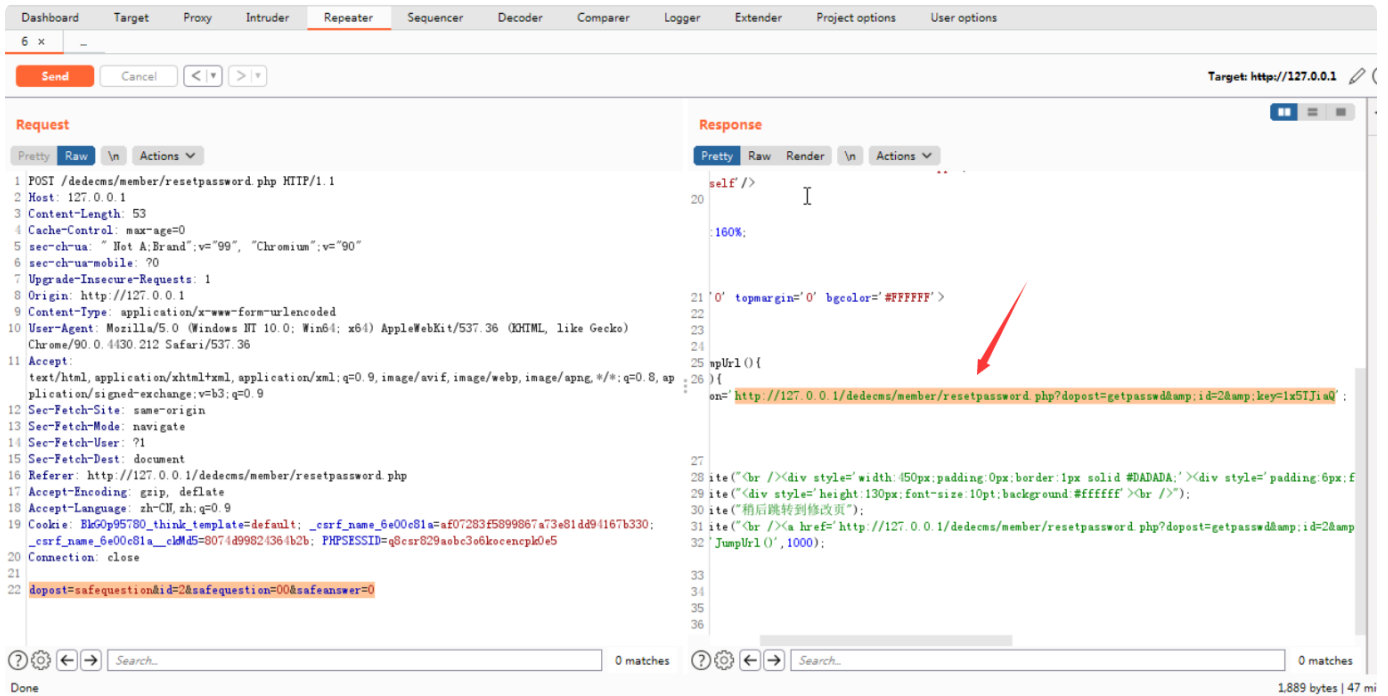
在进行用户密码重置时，php存在弱类型比较，导致逻辑绕过。只要知道任意用户的id，就可以对其进行密码重置。

构造payload，这里有get和post两种方法构造，分别如下：

post构造



发送后会返回一个修改密码的url，这个url包含了key

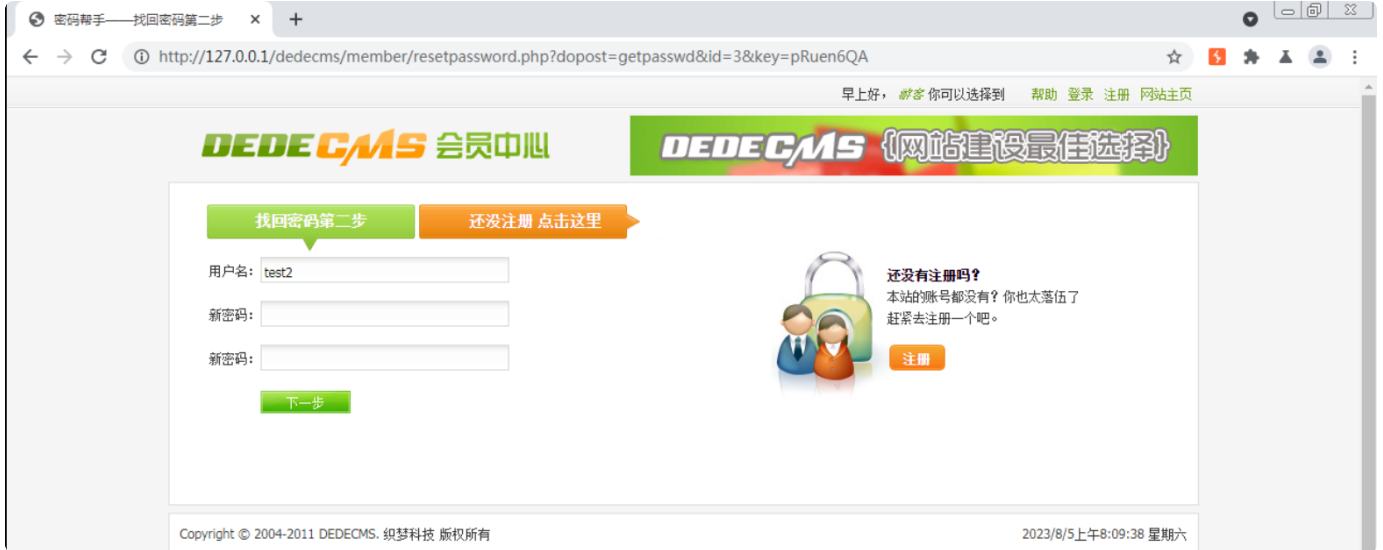
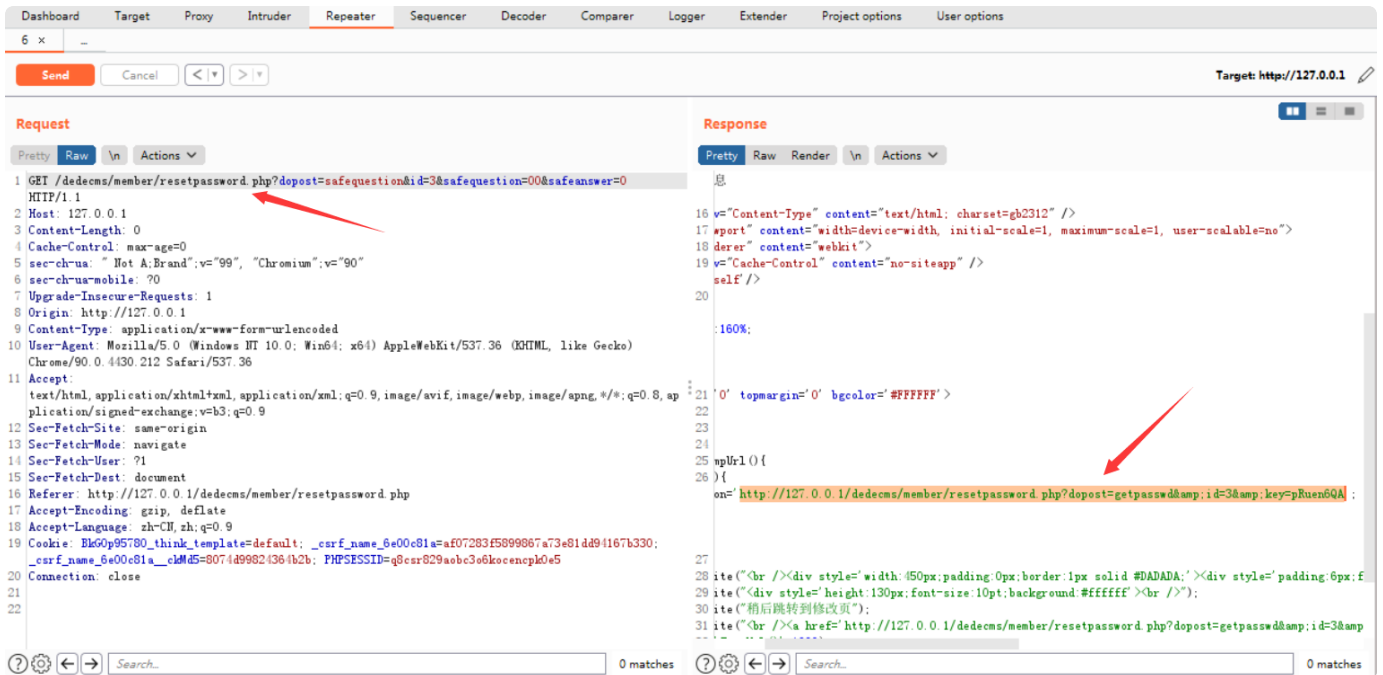


用这个key去重置密码，发现直接调到第二步，能修改任意用户的密码



get构造

方法一样，只是将post换成了get



10 条件竞争

“竞争条件”发生在多个线程同时访问同一个共享代码、变量、文件等没有进行锁操作或者同步操作的场景中。

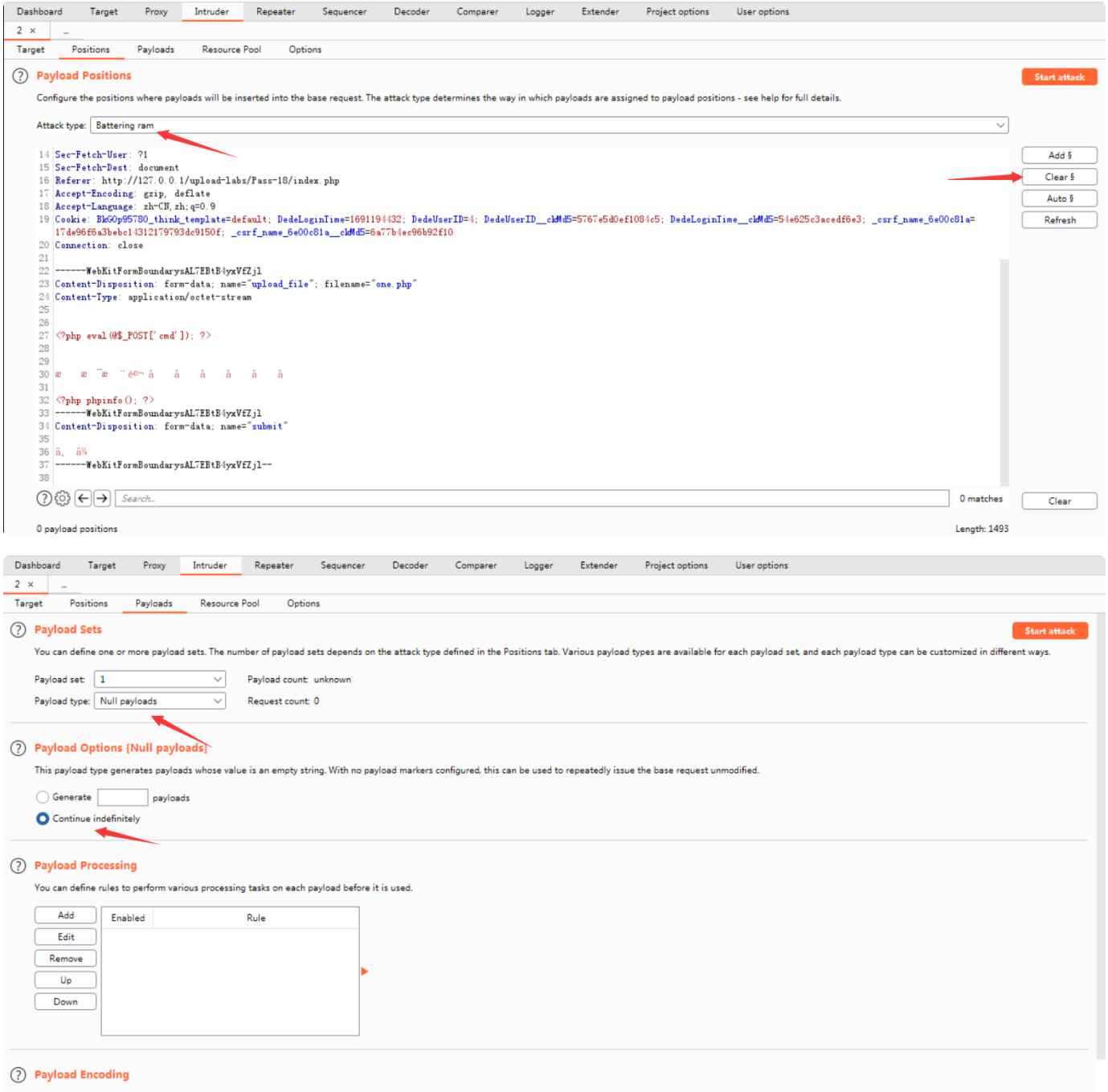
其实也就是当同时并发多个线程去做同一件事，导致处理逻辑的代码出错，出现意想不到的结果。比如签到、抽奖、领优惠券、文件删除等页面，都可能会有条件竞争漏洞。

upload-labs第18关复现

从代码中可以看出，先上传后判断，不是.jpg|.png|.gif类型再删除。

我们可以不断地上传php文件，同时不断地访问，如果在删除之前访问文件可以绕过。

直接上传一个php文件，然后进行抓包，将数据包发送至intruder下，进行以下设置



不断地尝试访问，有几率能访问成功

upload-labs

phpinfo()

+

← → ↻

http://127.0.0.1/upload-labs/upload/one.php

☆ ⚙ ⚙ ⚙ ⚙ ⚙

銀曼徽鍵L... 鐫竭揮鐫竭揮鐫竭揮

PHP Version 5.4.45

PHP Logo

System	Windows NT WIN7 6.1 build 7601 (Windows 7 Business Edition Service Pack 1) i586
Build Date	Sep 2 2015 23:45:20
Compiler	MSVC9 (Visual C++ 2008)
Architecture	x86
Configure Command	cscrip /nologo configure.js "--enable-snapshot-build" "--enable-debug-pack" "--disable-zts" "--disable-isapi" "--disable-nsapi" "--without-mssql" "--without-pdo-mssql" "--without-pi3web" "--with-pdo-oci=C:\php-sdk\oracle\instantclient10\sdk\shared" "--with-oci8=C:\php-sdk\oracle\instantclient10\sdk\shared" "--with-oci8-11g=C:\php-sdk\oracle\instantclient11\sdk\shared" "--with-encchant=shared" "--enable-object-out-dir=.\obj/" "--enable-com-dotnet=shared" "--with-mcrypt=static" "--disable-static-analyze" "--with-pgo"
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	C:\Windows
Loaded Configuration File	C:\phpstudy_pro\Extensions\php\php5.4.45nts\php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files	(none)